Riddle Me Zero: A One-Query Fresh-Message Forgery against Sphinx-in-the-Head

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

24 October 2026

AI provenance and review status. This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex generated and selected this paper's title and the scheme-specific "Riddle Me Zero" wordplay. OpenAI Codex performed AI-assisted target reconstruction, attack-history searching, cryptanalysis, implementation coordination, experiment coordination, and technical writing. A separate AI paper/profile review, hostile adversarial review, fresh-context independent reproduction, and final exact-target attack-history recheck passed. The exact public package was independently reviewed before release. Independent human verification has not been performed. It is optional, and there is no human-verification requirement.

Abstract

We analyze the current official 66-page version of *Sphinx-in-the-Head: Group Signatures from Symmetric Primitives*, IACR ePrint 2024/649, frozen by SHA-256. The construction computes $sid = H_1(msg \parallel str)$ and places sid, rather than the two raw operands, in its printed group-proof statement. At the frozen TEST2 profile, Appendix E.2 gives one- and two-block formulas satisfying $H_1(u) = H_1(u \parallel 0^{255})$. After one honest signing query on the empty bit string returns $\Sigma_0 = (u, stt, com, \pi_G)$, an adversary outputs the fresh 255-bit message u with $\Sigma^* = (0^{255}, stt, com, \pi_G)$. Both pairs induce the same sid. Ordinary typed-paper GVf accepts, and a permitted tracing query supplies a proof that TVf accepts for the honest member at epoch zero. This wins the paper's Figure-8 non-frameability game and is also a one-query adaptive fresh-message forgery.

A prospectively sealed, independently written standard-library model executed the complete typed GSig/GVf/Trace/TVf flow at $(n, q, h, d, k, NR, NU) = (255, 1024, 1, 16, 70, 1120, 70)$. One independent trial succeeded in 0.01501373597420752 seconds with 21,504 KiB peak `RUSAGE_SELF` and one worker; all eight controls rejected. This is a deterministic algebraic transformation, so the single trial is not a statistical success-rate estimate. The proof systems, credential service, LowMC, M-FORS, and MPC-in-the-Head components are idealized. The official HBGS repository is component-only and defines no outer message/randomizer mapping, codec, full verifier, or relevant known-answer test. We therefore make no author-byte, source-verifier, deployed-verifier, real-primitive, or secret-recovery claim.

1 Introduction

Chen, Dong, Newton, and Wang propose Sphinx-in-the-Head (SITH), a fully dynamic group signature built from symmetric primitives and an F-SPHINCS+ credential chain [1]. A member signs an arbitrary finite bit string using a fresh n-bit randomizer str. Both values are compressed to a signature identifier $sid = H_1(msg \| str)$ before the group proof is formed. Verification, tracing, and tracing verification reconstruct that same identifier.

Appendix E.2 gives concrete LowMC-based cases for one, two, and three n-bit blocks. In the one- and two-block cases, a zero second block is an alias: feed-forward XOR with 0^n changes nothing. The signature randomizer is public, so a signature on the empty message supplies exactly the block needed to move those same n bits from the randomizer field into the message field. Replacing the randomizer by zero then preserves sid and the complete printed proof statement.

This paper makes four contributions. First, it derives the zero-extension identity directly from the target formulas. Second, it completes the formal Figure-8 transcript, including the tracing query, exact-pair freshness, $\tau = 0$, and honest-member attribution. Third, it reports primary and fresh-context independent full-dimension typed-paper executions, together with public-only, mutation, revocation, and domain-separation controls. Fourth, it states a strict source and implementation boundary: the result is about the complete typed paper model, not an unprovided outer codec or a deployed binary.

We claim no novelty for Davies–Meyer hashing, zero-extension observations, fixed-point analysis, or message-randomizer retargeting in general. The contribution is their concrete application to the printed Sphinx-in-the-Head construction and its complete non-frameability endpoint.

2 Target, profile, and claimed security

The target is the official 66-page PDF of ePrint 2024/649, received on 28 April 2024. Its revision ordinal was not resolved, so the immutable target is identified by the digest

`67581ad5d1ae2455573cdb9b043344d91ca04788797318a7906ed500380a9881.`

The paper presents post-quantum group signatures and describes the selected row in a 128-bit quantum-security context. We record this as the authors' claim, not as an independent contemporary security estimate.

Item	Frozen value
Profile	`SITH-2024-649-HBGS-TEST2-N255-Q1024-H1-D16-K70-NR1120-NU70-Q128-G2P10-PAPER-ALG2-ZEROPAD`
Core tuple	$(n, q, h, d, k) = (255, 1024, 1, 16, 70)$
MPC schedule	$NR = 1120$, $NU = 70$, 16 parties
Group capacity	$2^{10} = 1024$ members
M-FORS public value	$dk = 1120$ bits
Top tree	70 roots, 58 appended 0^{255} leaves, capacity 128, height 7
Tree rule	Appendix-B Algorithm 2 zero padding; Appendix-E.5 lifting excluded
Security property	Dynamic group-signature non-frameability, Figure 8

Table 1: Frozen full-parameter typed paper profile.

The paper states that its prototype implemented the credential chain and group-proof signing/verification components, not the complete protocols. The official HBGS repository is pinned at the following Git identity:

```
commit e13fe83cdc4a636dd8c72a37545090eef99812b7
 tree 2cb34c40bff268dcdae3a1179ff6168f35fd91a4.
```

It is a component/test implementation [6]. It exposes neither complete outer Join, GSig, GVf, Trace, and Revoke interfaces nor a mapping from its 64-byte `message_digest` and 32-byte `nonce` buffers to paper *msg*, *str*, or *sid*. It also supplies no complete outer codec, arbitrary-length unary H_1 dispatcher, SITH known-answer test, or full verifier relevant to this transformation.

3 The typed paper construction

The group-signature syntax accepts $msg \in \{0,1\}^*$. For TEST2 the signer selects a 255-bit random string *str* and computes

$$sid = H_1(msg \parallel str), \tag{1}$$
$$stt = F(tk_u, sid), \tag{2}$$
$$sst = F(sk_u, sid), \tag{3}$$
$$gid = H_1(rpk). \tag{4}$$

The remaining credential computation derives a commitment *com*. The signer proves the printed relation whose public tuple is

$$(gp, rpk, gid, sid, stt, com), \tag{5}$$

and emits

$$\Sigma = (str, stt, com, \pi_G). \tag{6}$$

Raw *msg*, raw *str*, and the revocation list are not separately listed in the proof statement in Equation (5).

Ordinary GVf parses Equation (6), recomputes Equation (1) and *gid*, rejects if some tracing key in the supplied revocation list satisfies $stt = F(tk, sid)$, and otherwise verifies π_G on Equation (5). Ordinary Trace also recomputes *sid*, finds the member whose tracing key matches *stt*, and issues π_t for the public tracing tuple

$$(id_u, gid, stt, sid). \tag{7}$$

The tracing verifier TVf evaluates that relation for its supplied message and signature. Thus all four ordinary algorithms share the same typed *sid* boundary.

4 The zero-extension identity

The abstract construction selects $H_1 : \{0,1\}^* \to \{0,1\}^n$. Appendix E.2 gives the concrete one- and two-block cases

$$\mathsf{hash}_1(u) = \mathsf{low_mc}(u, 0^n), \tag{8}$$

$$\mathsf{hash}_{1a}(u, v) = \mathsf{low_mc}(u, v) \oplus v. \tag{9}$$

When these cases instantiate the two relevant *sid* evaluations, substituting $v = 0^n$ gives

$$H_1(u \,\|\, 0^n) = \mathsf{low_mc}(u, 0^n) \oplus 0^n = \mathsf{low_mc}(u, 0^n) = H_1(u). \tag{10}$$

Equation (10) is not a cryptanalytic break of LowMC, a collision search, or a block-cipher fixed-point computation. It is the literal zero feed-forward case of the printed Davies–Meyer-style formulas. Nor do we infer an unspecified framing rule for four or more blocks. The result needs only the exact one- and two-block cases at $n = 255$.

5 One-query fresh-message transformation

Let ϵ denote the unique zero-bit string. The adversary performs:

1. Call AddHU to create the honest member.
2. Query GSigHU(ϵ) once, receiving $\Sigma_0 = (u, stt, com, \pi_G)$ with $u \in \{0,1\}^{255}$.
3. Set $msg^* = u$ and $\Sigma^* = (0^{255}, stt, com, \pi_G)$.
4. Query TraceU(RL_0, msg^*, Σ^*), obtaining the honest identity and tracing proof π_t^*.
5. Output $(msg^*, \Sigma^*, \pi_t^*, \tau = 0)$.

The signing and forged identifiers are

$$sid_0 = H_1(\epsilon \,\|\, u) = H_1(u) = \mathsf{low_mc}(u, 0^{255}), \tag{11}$$

$$sid_* = H_1(u \,\|\, 0^{255}) = \mathsf{low_mc}(u, 0^{255}) \oplus 0^{255} = sid_0. \tag{12}$$

No secret is recovered. The transformation reads the public randomizer u and moves it across the unframed concatenation boundary while retaining the other three signature fields exactly.

6 Correctness and formal consequence

Theorem 1. *Assume that Appendix E.2's one- and two-block formulas instantiate the two relevant sid evaluations in the frozen typed paper profile. From one honest signature on ϵ, the transformation above produces a signature accepted on a fresh 255-bit message and wins Figure 8 at $\tau = 0$. Ordinary tracing and* TVf *attribute the output to the honest member.*

Proof. Equations (11) and (12) give $sid_* = sid_0$. The root public key and *gid* are global, while *stt*, *com*, and π_G are copied. Therefore every component of the printed public statement in Equation (5) is unchanged. The empty list RL_0 contains no tracing key, so ordinary $\mathsf{GVf}(msg^*, \Sigma^*, RL_0)$ reaches the same proof verification and accepts.

The TraceU oracle first applies this ordinary verification and then ordinary Trace. Since the preserved *stt* still equals $F(tk_h, sid_*)$, tracing finds the honest identity. Its proof π_t^* authenticates the same tuple in Equation (7), so the final TVf call accepts for that honest member.

The honest-response log contains only (ϵ, Σ_0). The forged message has width 255, whereas ϵ has width zero. They are unequal even if the numeric value sampled for u is zero. Hence strict message freshness holds, and the weaker Figure-8 requirement that the exact ordered pair (msg^*, Σ^*) be absent from the log also holds. All predicates in Figure 8 are therefore true. □

The tracing query is part of the non-frameability interface and supplies the game-required π_t^*. It is not an additional signing query. A rule that closed the game under reused tracing-token provenance rather than exact (msg, Σ) pairs would define a different game from the printed one.

7 Complexity and conditions

The attack makes one honest signing query and one permitted tracing query. Its own transformation copies three public fields and replaces the allocation of 255 public bits between *msg* and *str*; it requires no search, guessing, secret information, credential fabrication, or proof fabrication. Algebraic success is independent of the value of u. In particular, the probability that $u = 0^{255}$ creates no failure event because typed length still makes the forged message fresh.

The condition is specification-level: the Appendix-E.2 one-/two-block cases must govern the *sid* calls exactly as stated. A separately specified, injective framing of the two operands would block this route, but no such framing is present in the printed $H_1(msg \| str)$ expression or proof statement.

8 Full-profile reproduction

Two independently developed source-independent typed models reached the same endpoint. The corrected primary run used one trial and one worker, passed all 48 recorded checks, and took 3.48 seconds external wall time with 21,504 KiB peak RSS. A fresh-context developer then wrote the public clean-room line without inspecting or copying the delivered or primary attack code.

Run	Trials	Successes	Peak RSS	Time and scope
Corrected primary model	1	1	21,504 KiB	3.48 s external wall
Independent clean-room v2	1	1	21,504 KiB	0.01501373597420752 s internal

Table 2: Full-dimension typed-model executions. Neither time is a real-proof-system runtime.

The exact independent implementation is 48,001 bytes with SHA-256

`3b3b62d9018b28cda7a279fd2145697421f5b132a5d3728d6c99daf2178ee863,`

and its retained 7,526-byte evidence JSON has SHA-256

`f4b829edf9f822a8f44fbbf94108416a603571e7305d2e5bc1671e484995cfcd.`

The evidence validator passed 166 of 166 assertions, and a separate hostile result review found no blocker. The public program retains its historical “prospectively sealed, not executed” header so that its bytes remain exact; the sealed run and code/evidence hash binding establish that those same bytes were subsequently executed once.

The independent run reports one signing query on ϵ, one tracing query with RL_0, ordinary original and transformed acceptance, honest tracing identity, final TVf acceptance, strict message freshness, and Figure-8 return one. Both evaluated top trees used 70 real roots, 58 zero leaves, height 7, and no Appendix-E.5 node lift. The observed u was nonzero; the zero edge in Theorem 1 was established statically, not by forcing that rare sample.

All eight precommitted controls passed:

1. a public-only zero-query signature was rejected;
2. public credential synthesis was rejected;
3. public proof synthesis was rejected;
4. proof reuse on a changed public statement was rejected;
5. mutation of a signature field was rejected;
6. replacement by a fixed nonzero *str* was rejected;
7. verification under a revocation list containing the honest tracing key was rejected; and
8. a separate length-framed, domain-separated H_1 world rejected the transformation while accepting its original signature.

One success in one trial demonstrates the deterministic scoped transcript. It is not an empirical estimate of a random success probability. The independent internal interval ends after trial completion and before final JSON serialization and `fsync`; it is not a whole-process benchmark.

9 Evidence and implementation boundary

The independent program evaluates the exact paper types, ordinary algorithm flow, TEST2 dimensions, Figure-8 predicates, and Algorithm-2 top-tree shape. To avoid vacuous public forgeries inside the model, credential issuance and the two proof systems are stateful, hidden-key ideal capabilities. They verify the printed witness relations before issuing statement-bound tags. Public views can verify but cannot issue credentials or create proofs.

The implementation uses an independently domain-separated ideal surrogate for LowMC, ideal M-FORS base values and credential-chain signatures, and a typed fallback for H_1 input shapes outside the printed one-, two-, and three-block cases. It does not execute real LowMC, M-FORS, F-SPHINCS+, KKW, Picnic, MPC-in-the-Head, Fiat–Shamir/NIZK, serialization, or parsing. The attack equality itself uses only the exact one-/two-block formulas.

The official source commit and tree were stable, although GitHub archive transport bytes differed between two acquisitions. That is retained as an archive-byte qualification, not evidence of source-tree divergence. No upstream source is included in the reproducer. Nothing here establishes official-source interoperability, author-byte acceptance, a deployed verifier, or a normative mapping for the source's external digest and nonce buffers.

The evidence records are consistent with one authorized invocation, but the absence of another artifact is not an operating-system audit of all historical execution. These provenance limits do not affect the algebraic identity; they bound the empirical claim.

10 Related work and attack history

The component formulas are Davies–Meyer-style block-cipher hashing as standardized and discussed in generic hash literature [2]. Prior work studies fixed-message-length requirements for symmetric-key accumulator and ring-signature constructions [3], randomized hashing in digital signatures [4], and generic fixed points of block-cipher-based hashes [5]. Those works are conceptual background. They do not report this SITH transformation or its full non-frameability endpoint, and we make no general technique-novelty claim.

The closest exact-paper criticism located was DGSP, ePrint 2025/760, which discusses signature size and opening efficiency or scalability rather than a forgery, recovery result, or non-frameability break. Generic results about SPHINCS+, FORS, LowMC, Picnic, or MPC-in-the-Head concern different targets or components.

No prior public substantive attack against the exact scheme, version, and profile was located in the searches performed as of 2026-10-24. Confidence is high for indexed exact-target literature and official/public repository surfaces and medium-high globally. The search was bounded by HTTP 403 and WAF blocks, GitHub rate limits, paywalls, disagreement and lag among citation indexes, and the unavoidable possibility of private, deleted, embargoed, or unindexed material. The statement is date-bounded rather than an absolute priority claim.

11 Repair direction

An unambiguous, injective encoding should separate *msg* from *str*, for example by domain separation and explicit bit lengths, and that same encoding should be used consistently by GSig, GVf, Trace, and TVf. A complete arbitrary-length H_1 specification, outer codec, verifier, and known-answer tests should cover the zero-length and block-boundary cases. The raw typed operands, or a binding encoding of them, may also be incorporated into the proof statement. This is a repair direction, not a proved drop-in patch; a revised construction would require a new proof and interoperability testing.

12 Limitations

1. The result assumes the printed Appendix-E.2 one-/two-block formulas govern the two *sid* calls. It does not supply a missing general arbitrary-length dispatcher.
2. The result is a source-independent typed-paper attack, not an official-source, byte-codec, interoperable, or deployed-verifier run.
3. LowMC, M-FORS, F-SPHINCS+, MPC-in-the-Head, and both proof systems are not executed as real primitives; the proof and credential services are sound ideal capabilities.
4. No secret key, equivalent key, credential, proof witness, or authority secret is recovered.
5. One independent trial supports a deterministic transcript, not a statistical success-rate estimate. The $u = 0^{255}$ edge is static, not empirically observed.
6. The recorded internal runtime excludes final serialization and disk synchronization and is not an end-to-end author-implementation cost.
7. Appendix-B Algorithm-2 zero padding is selected; no equivalence with Appendix-E.5 lifting is claimed.
8. The official repository lacks the outer mapping and relevant KAT, and differing archive transport bytes prevent an archive-byte identity claim even though the Git commit and tree match.
9. Artifact preservation supports, but cannot independently prove at the operating-system level, that no unrecorded invocation ever occurred.
10. The attack-history conclusion is bounded by the recorded searches and their access and indexing limitations.

13 Reproducibility

The public package retains the independent implementation and evidence byte-for-byte. Quick mode validates existing evidence without importing the model:

```
./reproducer/reproduce.sh -quick
```

A fresh post-publication user run requires an explicit nonexistent path:

```
./reproducer/reproduce.sh -full fresh-evidence.json
```

The latter starts a new random trial and then applies the standalone evidence validator. The validator hashes the model as data; it does not import it. The paper, scripts, evidence, reference outputs, and package checksums are included with no external Python dependency.

14 Conclusion

The result is best described as a one-query adaptive fresh-message non-frameability forgery in the complete typed paper model. It changes the allocation of the same 255 bits between *msg* and *str*, leaves the proof statement unchanged, and causes ordinary verification and tracing to accept and blame the honest member. It is not an implementation-level LowMC, M-FORS, MPC-in-the-Head, source-code, codec, or deployed-system claim.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

[1] L. Chen, C. Dong, C. J. P. Newton, and Y. Wang, "Sphinx-in-the-Head: Group Signatures from Symmetric Primitives," *IACR Cryptology ePrint Archive*, Report 2024/649, 2024. https://eprint.iacr.org/2024/649; doi:10.1145/3638763.

[2] International Organization for Standardization, *ISO/IEC TR 10118-2:2010—Hash-functions using an n-bit block cipher*, 2010.

[3] D. Derler, S. Ramacher, and D. Slamanig, "Post-Quantum Zero-Knowledge Proofs for Accumulators with Applications to Ring Signatures from Symmetric-Key Primitives," in *PQCrypto 2018*, LNCS 10786, pp. 419–440, 2018. doi:10.1007/978-3-319-79063-3_20; ePrint 2017/1154.

[4] P. Gauravaram and L. R. Knudsen, "On Randomizing Hash Functions to Strengthen the Security of Digital Signatures," in *EUROCRYPT 2009*, LNCS 5479, pp. 88–105, 2009. doi:10.1007/978-3-642-01001-9_5.

[5] J.-P. Aumasson, *Analysis and Design of Symmetric Cryptographic Algorithms*, doctoral thesis, EPFL, 2009.

[6] University of Surrey SCCS, "HBGS: test implementation for Sphinx-in-the-Head," commit `e13fe83cdc4a636dd8c72a37545090eef99812b7`. https://github.com/UoS-SCCS/HBGS.